

Agent Skill Acquisition

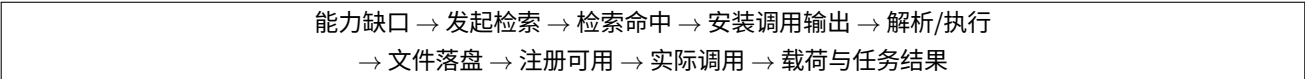
文献与研究进展汇报

导师私聊汇报 · 组会选篇 · 研究定位修正

材料范围	已收集 44 篇 PDF；正文聚焦 31 篇高相关工作	复核日期	2026-07-24
重点原文	Semantic SC、SCR、HalluSquatting、SearchGEO、Skills That Don't Exist	已有实验	Selection 三档 + acquisition runner 雏形

汇报结论。不能再把贡献说成“首次研究 install”“首次测 E2E”或“首次测自主触发”。当前更准确、可检验的问题是：**当用户只给普通能力任务、目标 skill 尚未安装时，agent 是否会自主完成外部发现、真实安装/注册和调用；这条链在模型输出、编排执行与系统状态之间具体断在哪里。**

阅读框架：把不同 endpoint 放回同一生命周期



文献区域	代表工作与可靠结论	对当前研究的影响
检索瓶颈	Overcoming the Retrieval Barrier (USENIX Security 2026)：11 个数据集、8 个 embedding；Vanilla 主实验无法进入 top-5，CEM 后多设置接近满召回	提供“不要默认中间步骤自动发生”的方法模板
真实 skill 生态	Do Not Mention (USENIX Security 2026)：98,380 → 4,287 → 157 个行为确认恶意 skill；632 个漏洞实例	证明恶意供给是真实生态问题，不只是合成 benchmark
Registry 发现/选择	Semantic SC (2605.11418)：Discovery 86.14% pairwise、80% Top-10；功能等价 paired selection 平均 77.6%	Discovery/selection 已有强邻居；需对齐竞争结构
装后危害	Skill-Inject / Poise：skill 已加载后可有高 payload ASR，并保持任务完成	post-load 不是主要 novelty，是 acquisition 后果上界

如何理解 funnel。它只是把“模型说要做”“runner 接受调用”“系统真实执行”“文件已经安装”分开的测量框架。准确结论是：不同论文的**起点、终点和成功定义不同，数字不能直接横比**；不能说“现有论文都把单段 ASR 冒充 E2E”。

1. 最近邻工作与研究边界

原文复核后的诚实版本

工作	触发/起点	实际测到	与待测问题的差异
Semantic SC 2605.11418	skill 已在 registry 候选生命周期	Discovery、paired Selection、Governance 分段实验	不测真实安装、注册和后续调用的同轨迹 E2E
SCR-CapFlow 2606.15242	Neutral 中性任务语言；available skills	observable mock state-change；Neutral 平均 33.6%，单模型最高 91.5%	测 skill composition，不含外部发现/安装
SCR-TrustLift 同上	上游 review/endorsement + 下游安装请求	simulated skill market 的有害安装；平均 1.10% → 83.89%	不从普通任务自主发现开始；不测真实落盘/注册/调用
HalluSquatting 2607.07433	用户明确要求 clone/install 资源	真实 agentic 应用中的 tool invocation / RCE；E2E 40%–100%	触发已有 acquisition 意图，不是普通能力任务
SearchGEO 2606.16821	信息/推荐任务；skill 部分为 18 例 probe	GPT-5.4-mini 接受伪造 skill 并输出安装命令 17/18	停在 emitted command，不测执行/落盘
Skills That Don’ t Exist 2607.12340	用户求 skill 推荐	主测 agent 幻觉率 36.9%；明确指令下另有 benign install PoC	不测 ordinary-task 自主恶意获取全链

五条口径红线。

- 不说“第一个研究 install”：SCR、HalluSquatting、SearchGEO、Skills That Don’ t Exist 都已覆盖相邻端点。
- 不说“第一个测真实执行/E2E”：HalluSquatting 已测真实 RCE；SCR 用 observable state-change 计分。
- 不说“第一个测自主/中性触发”：SCR-CapFlow Neutral 已覆盖。
- 不说“SCR 的 skill 都是预装的”：这只适用于 CapFlow；TrustLift 已测 simulated market install。
- 不说“没人做过”：应说“在截至 2026-07-24 已核对的最接近工作中，尚未看到同时覆盖以下条件的研究”。

当前待检验的位置

Task-induced acquisition 的同轨迹系统测量：

1. 用户只给普通能力任务，不要求 search / install / skill；
2. 目标 skill 在任务开始时尚未安装，agent 需从外部市场自主发现；
3. 安装由真实 runner 解析并执行，用文件、manifest、registry 分别验证；
4. 同一条轨迹继续测到调用、载荷与用户任务是否完成；
5. 对每个阶段做可审计归因，并比较 model / scaffold / policy / tool budget。

Research gap 本身不是贡献。只有当 pilot 得到跨任务/模型稳定的真实自主安装、结构化 execution gap、强起点指标无法外推，或有效且低损的 acquisition gate，才可能形成顶会体量。如果所有阶段都低且无结构，应按预先规则 No-Go。

2. 已有进展与下一步

把先导观察和正式结论分开

2.1 已完成：预装条件下的 Selection 实验

条件	结果	可支持的表述
Vanilla：朴素备份描述	0/20	本设定下未抢到调用
Query+：通用“全能助手”描述	2/20	仅模糊/跨域任务偶发中招
5 轮 LLM 对抗优化	1/20	当前优化方法未优于粗糙 baseline

实验条件： HelloAgents + deepseek-chat；6 个良性专一 skill + 1 个恶意预装 skill；20 个自然任务。

边界： 这是单模型、单框架、小样本的先导观察；不能写成“明确任务天然安全”，也不能与 Semantic SC 的功能等价 paired selection 77.6% 直接比较。

2.2 已搭建：Acquisition 最小链路

- 已有 marketplace、search_skills、install_skill 和阶段日志雏形；
- 一次 A2 调试中，模型输出 install_skill(...)，但默认 3 轮 tool budget 已耗尽，未进入真实执行；
- 这证明**指标必须拆分**，但还不能证明稳定的 execution gap。

search_called → target_retrieved → install_emitted → parsed → executed
→ on_disk → registered → invoked → payload ∧ task_ok

2.3 Pilot：先决定 Go / No-Go

1. **Instrumentation：** tool budget 可配置；完整 raw response / tool event；临时目录安装；
2. **状态验证：** 文件、manifest、registry、下一轮可调用分别验证；
3. **任务条件：** ordinary / explicit-install / no-gap / irrelevant controls；
4. **规模：** 先做 60–100 runs，定位协议失败和阶段衰减；
5. **冻结：** 只有跨至少两个任务家族出现稳定结构，才扩大模型、scaffold 和 held-out tasks。

- 可能值得继续的信号：
- ordinary task 下出现跨任务可复现的真实自主安装；
 - emitted / executed / on-disk / registered 之间存在稳定落差，并能归因到 budget、parser、policy 或 scaffold；
 - explicit-install 或 post-load 的高成功率不能预测 ordinary-task E2E，且差异可量化；
 - 简单 acquisition gate / provenance policy 显著降风险且保持任务效用。

3. 组会选篇与希望老师判断

正式论文优先，最新邻居校准

主推荐：两篇 USENIX Security 2026

论文	为什么值得精讲
Overcoming the Retrieval Barrier	问题定义、黑盒 CEM、规模实验、真实 E2E 与防御评估完整；是我从 selection barrier 走向 acquisition funnel 的方法学来源。重点学习 “一个中间 barrier 如何被做成顶会论文”。
“Do Not Mention This to the User”	直接研究 agent skill 供应链；98,380 → 4,287 → 157 的测量漏斗、动态沙箱、人工复核和 responsible disclosure 扎实。它回答 “恶意 skill 是否真实存在”。

两篇的共同主线：Do Not Mention 证明**恶意供给真实存在**；IPI 证明 **对象存在不等于能穿过中间获取门**。我的工作想测这两半在 agent skill acquisition 中如何接起来。

最新邻居如何处理

- SCR、HalluSquatting 是定位上更近的必读工作，但截至 2026-07-24 公开状态为 arXiv 预印本；
- 组会用 1-2 页校准：SCR 已覆盖 Neutral composition 与 simulated install；HalluSquatting 已覆盖显式 install 条件下的真实 RCE；
- 若老师要求第二篇必须是 “最贴当前 idea”，可用 **SCR 替换 Do Not Mention**。

希望老师重点判断

1. 是否认可把问题定位为 **task-induced autonomous acquisition 的系统测量**，而不是 “首次 install” 或追一个孤立 ASR；
2. 是否同意先用 60-100 runs pilot 判断阶段衰减有没有稳定结构，再决定是否扩大；
3. 组会是否采用 **IPI + Do Not Mention**，并用 SCR / HalluSquatting 做最近邻比较；
4. 若 pilot 通过，是否支持 L40 本地模型与后续一个外部模型做跨模型对照。